GRC Risk Register Starter

Use this workbook to learn a repeatable method. Write what you observed separately from what you infer; never present fictional sample data as a real incident or production assessment.

1. Define the scope and rating scale

FICTIONAL TRAINING EXAMPLE The sample risks below are examples for practice, not an assessment of a real organisation. Define likelihood and impact criteria before scoring; colours or a multiplied score do not replace judgement.

Planning field	Learner entry
System / business outcome	
Assets and data in scope	
Risk owner / participants	
Likelihood scale definition (1-5)	
Impact scale definition (1-5)	
Review date and known assumptions	

2. Write risk statements

A useful risk statement links an asset or outcome, a plausible event, and the potential consequence. Avoid wording that implies an incident has already happened unless evidence supports it.

Asset / outcome	If (risk event)	Then (consequence)	Current control / evidence	Owner

3. Risk register

ID	Likelihood	Impact	Rationale / evidence	Treatment	Owner / due date	Status
R-001				Mitigate		Open
R-002				Mitigate		Open
R-003				Review		Open
R-004						Open

4. Map controls to evidence

Risk ID	Control outcome	Evidence that could verify it	Gap / limitation	Next action

5. Decision summary

- ☐ Each rating has a written rationale and defined scale.
- ☐ Every open risk has an owner or a documented reason it is unassigned.
- ☐ Treatment choices and review dates are explicit.
- ☐ Evidence gaps and accepted risks are visible.
- ☐ Framework mappings are not presented as proof of compliance.

Top three priorities and why:

Decision or support requested from a stakeholder:

REMEMBER A policy or control description says what should happen. Evidence is what helps show whether it actually happens.

A real lab for these notes

Topic: Governance, risk scoring, controls, current/target profile gaps, and evidence. These pages connect the existing OpenCyberPath notes to specific provider-hosted exercises. The card label is intentionally generic; the exact task name and direct URL are listed here so you can open the right exercise instead of a whole catalogue.

Concept checkpoints

- State the asset, threat event, vulnerability/condition, likelihood, impact, and existing control.
- Explain likelihood and impact scales before assigning scores.
- Use a current-vs-target profile to make gaps explicit; do not equate a template with compliance certification.
- Every risk needs an owner, treatment decision, due date, and evidence that can be checked.

CSF 2.0 Organizational Profiles *[NIST]*
https://www.nist.gov/cyberframework/profiles
Access note: Official template download for current and target profiles. This is a framework exercise/spreadsheet, not a virtual machine lab.

Evaluate regulatory compliance in Defender for Cloud *[Microsoft Learn]*
https://learn.microsoft.com/en-us/training/modules/evaluate-regulatory-compliance/
Access note: Direct guided module with assessment. A live cloud tenant may be needed for some hands-on steps and can incur charges.

ACCESS CHECK Open the exact task page and verify the current login, account tier, VM launch button, free/paid terms, and any cost notes before starting. A provider may change availability or retire a challenge.

Before you click Start

- Write down the provider's target/scope and use only the instance it creates for you.
- Keep this notebook beside the exercise. Use its original course data before trying commands on a local machine.
- Capture timestamps, filenames, row/packet IDs, and a short explanation; redact credentials, tokens, and personal data.
- If a page says retired, premium, or downloadable-only, use the alternative listed in the access note or return to the matching interactive lab above.

Commands you can explain

This practice uses fictional assets and spreadsheet data. Do not place real company security weaknesses or confidential information in the public training site.

First download the matching sample file(s) from the existing card when a command names one. Keep the data in a practice folder and never execute strings stored in evidence.

POWERSHELL / INSPECT THE CSV TEMPLATE

```
Import-Csv .\grc-risk-register-starter.csv | Format-Table -AutoSize
```

Read the bundled fictional risk rows. Adjust if you have saved the template under another name.

POWERSHELL / HASH WORKSHEET

```
Get-FileHash .\grc-risk-register-starter.csv -Algorithm SHA256
```

Record the exact training worksheet version used in a report.

PYTHON / CHECK CSV HEADER

```
python -c "import csv; print(next(csv.reader(open('grc-risk-register-starter.csv',
encoding='utf-8'))))"
```

Print the CSV column headers only. Run from the directory containing the sample file.

GIT / KEEP TRACK OF YOUR OWN NOTE CHANGES

```
git status --short
```

If you maintain a study repo, check which files you changed before committing. Never add credentials or real confidential risk data.

COMMAND HABIT Check the current working directory, shell, target, and expected effect before pressing Enter. Save the exact command and the output that mattered.

Guided lab run

- 1. Open the NIST CSF 2.0 profile template and use a fictional organisation or class scenario.
- 2. Define likelihood and impact criteria, then record the current state and desired target state separately.
- 3. Map each gap to an outcome/control, risk owner, treatment, due date, and evidence request.
- 4. Prioritise using documented reasoning, not just a multiplied score or colour.
- 5. If completing the Microsoft Learn module, check the subscription/tenant before any hands-on cloud action; do not provision paid services for the worksheet.

Evidence checklist

- [ ] What exact lab instance or sample file was used?
- [ ] Which command/query and time range produced the observation?
- [ ] What is the directly observed fact, separate from your inference?
- [ ] What benign/alternative explanation could fit?
- [ ] What extra record or control would help confirm the conclusion?

Check your understanding

Q Does a completed profile prove an organisation is compliant?

Think it through: No. It is a structured description of current/target outcomes and gaps, not a certification or audit opinion.

Q Why document a risk owner and due date?

Think it through: Without accountability and timing, the register is only a list and cannot show treatment progress.

Q How should a risk be closed?

Think it through: Record the control evidence, test method, residual risk, approver, and review date.

NOTEBOOK CLOSE-OUT Finish with: Observation / Evidence source / Why it matters / Alternative explanation / Next check / Limitation. A careful "not enough evidence yet" is a valid professional result.